

🔒 СВОДНЫЙ КОНСОЛИДИРОВАННЫЙ ПАСПОРТ БЕЗОПАСНОСТИ ФРОНТЕНДА ПАНЕЛИ

Настоящий итоговый документ представляет собой высокоуровневое описание, паспорт ИБ и архитектурный разбор сквозного взаимодействия всех модулей клиентской логики (JavaScript). Документ обобщает транзакционные барьеры, ИБ-затворы и механизмы защиты от XSS/CSRF атак.

--- Единая сквозная схема движения данных фронтенда ---

СТАРТ СТРАНИЦЫ (document.DOMContentLoaded)

↓ Запуск ядра инициализации (app.js)

1. КРИПТОГРАФИЧЕСКИЙ JWT-ПЕРЕХВАТ И СЕПАРАЦИЯ КОНТЕЙНЕРОВ

atob() распаковка Payload токена —► Каскадное вырезание запрещённого UI (.remove())

↓ Запрос к API-периметру через ИБ-обёртку (config.js)

🔒 **secureFetch(url)**: Автоматическая инъекция Bearer JWT-токена в заголовки HTTPS
🔴 **ПЕРЕХВАТ 401**: Мгновенное выжигание ключей (removeItem) + жесткий reload() ОЗУ
🛡️ **САНИТИЗАЦИЯ (showAlert)**: Аннигиляция тегов регулярным выражением `/<[>]*>/g` от XSS

↓ Разветвление по исполнительным JS-интерфейсам

auth.js

submit Входа +
Аварийный
масочный фильтр
ролей

servers.js

Реестр СУБД + Пул
Тестов связи
(parseInt)

panel_users.js

Дедупликация кэша
ОЗУ Set() + Root
Guard admin

security_rights.js

Кадровая изоляция
хостов по user_id

↓ Веерный накат или логирование (rights.js / smtp.js)

БЭКЕНД FASTAPI —► АТОМАРНЫЙ ЖУРНАЛ ИБ-АУДИТА AUDIT_LOGS

--- Подробное описание и профили ИБ-защиты системных модулей (app.js / config.js) ---

- **Главный координатор интерфейса и DOM-периметра (app.js)**

- Зона ответственности: Холодный старт приложения, первоначальная сепарация контейнеров видимости и каскадный ролевой контроль.
- Механизмы ИБ-защиты: Полный отказ от использования текстовых переменных роли из локального хранилища браузера для построения логики доступов. Модуль снайперски извлекает сессионный токен и выполняет низкоуровневую распаковку Payload методом

`atob()`. За легитимную роль принимается исключительно значение `tokenData.role`, подписанное сервером. При обнаружении несоответствия каст (например, при попытке администратора войти в интерфейс ИБ-Офицера), код не просто скрывает вкладки стилями, а физически аннигилирует элементы `createTabNavItem.remove()` из DOM-дерева страницы, исключая их восстановление через DevTools.

- **Сетевой ИБ-перехватчик и криптографический оберточный шлюз (config.js)**

- Зона ответственности: Сквозное проксирование HTTPS-запросов, инъекция Bearer JWT-токенов, ротация сессий и глобальная санитизация вывода.
- Механизмы ИБ-защиты: Паттерн «Обертка» (Wrapper) перехватывает все вызовы нативного метода `fetch()`, автоматически подмешивая заголовки авторизации. При получении ответа `401 Unauthorized` в процессе работы, активируется Контур А, который атомарно выжигает скомпрометированные ключи из памяти браузера и принудительно вызывает `window.location.reload()`, полностью очищая буферы ОЗУ. Централизованный фильтр `showAlert` задействует жесткий регулярный ИБ-затвор `message.replace(/<[>]*>/g, ' ')`, который намертво вырезает вредоносные теги, предотвращая Stored/Reflected XSS-атаки через подмену текстов ошибок СУБД. Вывод принудительно замыкается на нативную функцию браузера `alert()`, изолированную от DOM-дерева.

--- Подробное описание и профили ИБ-защиты системных модулей (auth.js / smtp.js) ---

- **Контур аутентификации, сессий и аварийных фолбеков (auth.js)**

- Зона ответственности: Перехват отправки форм авторизации, асинхронный опрос API входа, фиксация JWT-токенов в памяти и каскадный сброс ОЗУ.
- Механизмы ИБ-защиты: Модуль защищен от атак деградации привилегий (Downgrade Attacks) с помощью жесткого масочного фильтра `username.toLowerCase()`. Если бэкенд из-за сбоя СУБД или сетевого тайм-аута возвращает пакет без явного указания роли, фронтенд не сбрасывает сессию в безлимитные права администратора, а принудительно накладывает строгое ролевое зажатие `Security_Manager` при наличии корней `sec/manager/officer`. Текст ошибок выводится исключительно через экранированное свойство `data.detail`, исключая инъекции XSS. При деавторизации (`logoutSession`) вызов `window.location.reload()` гарантированно очищает буферы ОЗУ и затирает следы для отладчика.

- **Контроллер конфигурации и тестирования почтового шлюза (smtp.js)**

- Зона ответственности: Валидация параметров SMTP, проксирование проверочных пакетов связи и анимационный контроль кнопок ввода.
- Механизмы ИБ-защиты: Для предотвращения Flood-атак и спама кликов (Click-Flood Protection) при отправке алертов, модуль взводит жесткий UX-затвор `btnSubmit.disabled = true` и меняет текст на `Отправка...`. Это защищает сокет бэкенда от дублирующихся параллельных задач. Использование обязательной секции `finally` гарантирует снятие блокировки кнопки при любом исходе транзакции (включая обрывы связи и тайм-ауты), исключая замораживание интерфейса. Передаваемые порты шлюза принудительно очищаются методом `parseInt(..., 10)`, блокируя отправку текстовых инъекций.

--- Подробное описание и профили ИБ-защиты системных модулей (panel_users.js / security_rights.js) ---

- **Модуль администрирования, дедупликации ОЗУ и Root Guard (panel_users.js)**

- Зона ответственности: Атомарный накат лимитов, динамическая валидация required-полей, пагинация DBA и защита root-прав.
- Механизмы ИБ-защиты: Модуль реализует жесткий затвор самоликвидации системы (`r.username === 'admin'`), наглухо отключая атрибутом `disabled` кнопки деактивации и каскадного удаления для главного администратора панели. Для ликвидации Декартова раздувания ОЗУ-кэша (`LEFT JOIN Explosion`) при выгрузке связей один-ко-многим, контур производит рантайм-схлопывание дубликатов в уникальные хэш-таблицы объектов `Set()` строго по первичному ключу `id`. Все инлайн-обработчики `onclick` защищены от выхода из строковых границ внедрением регулярного выражения `.replace(/'/g, '\\')`, блокирующим атаки типа Quote Breaking XSS.

- **Изолированный контур кадрового надзора Офицеров ИБ (security_rights.js)**

- Зона ответственности: Снайперский JWT-перехват, принудительное вшивание ИБ-режима `CREATE_ONLY` и горизонтальная изоляция хостов.
- Механизмы ИБ-защиты: Разработан в жестком соответствии с принципом разделения обязанностей (`Separation of Duties`). Параметр `action_mode: "CREATE_ONLY"` намертво зашит в JS-код сборщика payload-пакета, что лишает ИБ-офицера физической возможности сбросить или перехватить пароль действующего суперадминистратора. Контур `usersList.filter` осуществляет строжайшую кадровую изоляцию: на экран выводятся только те инстансы СУБД, чей `user_id` совпадает с декодированной из JWT личностью оператора, полностью блокируя горизонтальное расширение привилегий. Анонимные модификации пресекаются стоп-затвором `!foundUsername`, который рубит трансляцию пакетов при невозможности идентифицировать сессию для журнала аудита.

--- Описание модуля веерного наката и консолидированная ИБ-матрица фронтенда ---

- **Модуль веерного распределения привилегий и каскадов автокомплита (rights.js)**

- Зона ответственности: Динамическое каскадное наполнение списков СУБД, веерный обход массивов баз данных, постраничная пагинация логов и защита от сетевого дребезга.
- Механизмы ИБ-защиты: Пошаговый ввод символов оператором зажат в жесткий рантайм-затвор `if (dbName.length < 3 && dbName !== 'ALL')`. Обрубки слов менее 3 символов немедленно отсекаются, блокируя флуд-генерацию паразитных SQL-запросов к каталогам `pg_roles` и `pg_namespace` при каждом нажатии клавиши. Все параметры фильтрации логов перед конкатенацией в строку URL принудительно экранируются встроенным методом `encodeURIComponent()`. Это исключает проведение атак на подмену HTTP-параметров (HTTP Parameter Pollution). При сетевых отказах удаленных инстансов активируется Fail-Fast затвор, прерывающий выполнение всего веера баз через `return`, изолируя транзакции от хаотичных сбоев.

--- Сводный чек-лист ИБ-соответствия клиентской части (фронтенда) ---

- Защита от подмены ролей в локальной памяти -> Использование роли строго из Payload JWT.
- Защита от Stored/Reflected XSS-атак -> Регулярное выражение `replace(/<[>]*>/g, ' ')`.
- Противодействие XSS в инлайновых onclick -> Экранирование одинарных кавычек через `replace(/'/g, '\\')`.

- Горизонтальное расширение прав (Horizontal Privilege Escalation) -> Кадровая изоляция хостов по user_id сессии.
- Защита сокетов бэкенда от DoS-дрезбзга -> Блокировка отправки строк короче 3 символов.
- Нарушение бизнес-логики SoD и перехват паролей -> Жесткое принудительное вшивание "CREATE_ONLY".
- Зависание кнопок при крахе сетевых fetch-запросов -> Вынос разблокировки элементов в блоки finally.
- Атаки на обход URI-маршрутизации бэкенда -> Сквозное экранирование через encodeURIComponent().